



توثيق مساهمة فردية

مصيصة البوابة الجامعية ومركز عمليات الرصد

University Portal Honeypot & SOC Console

مهدي سميح خليل مليحه

الاسم

120235744

الرقم الجامعي

2026 / 08 / 29

تاريخ التوثيق

mahdeps/university-honeypot

المستودع

وثيقة تبين ما بنيته بنفسي وما اكتفيت بربطه من عمل زملائي

1 ملخص تنفيذي

المشروع مصيدة ويب متوسطة التفاعل تحاكي بوابة خدمات طلبية كاملة، مبنية لتجذب المهاجم إلى نظام طعم معزول وتسجل كل ما يفعله وتصنّفه، ثم تعرضه على لوحة رصد تشبه ما يستخدمه محلّ أمن حقيقي. النظام يعمل على طبقتين: طبقة التطبيق التي بنيتها بالكامل، وطبقة الشبكة التي جاءت من نظام كشف تسلل دُرّب على يد زميل وقمت أنا بربطه ودمج مخرجاته.

الفكرة المحورية التي بُني عليها الدمج هي أن كل حدث في النظام — سواء التقطه التطبيق أو التقطه مستشعر الشبكة — يُفهرس بعنوان المصدر نفسه. هذا جعل دمج الطبقتين شبه مجاني: صفّ واحد في اللوحة يعرض ما رآه المستشعر على السلك وما رآه الطعم في الحمولة، تحت درجة تهديد واحدة.

44

إشارة بصمة

575,250

صف في قاعدة
الطعم

39

صفحة بوابة

14

وحدة برمجية

4,939

سطر بايثون

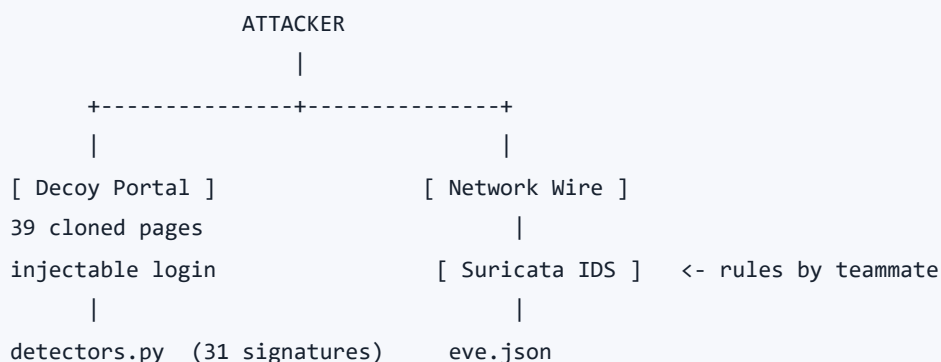
34

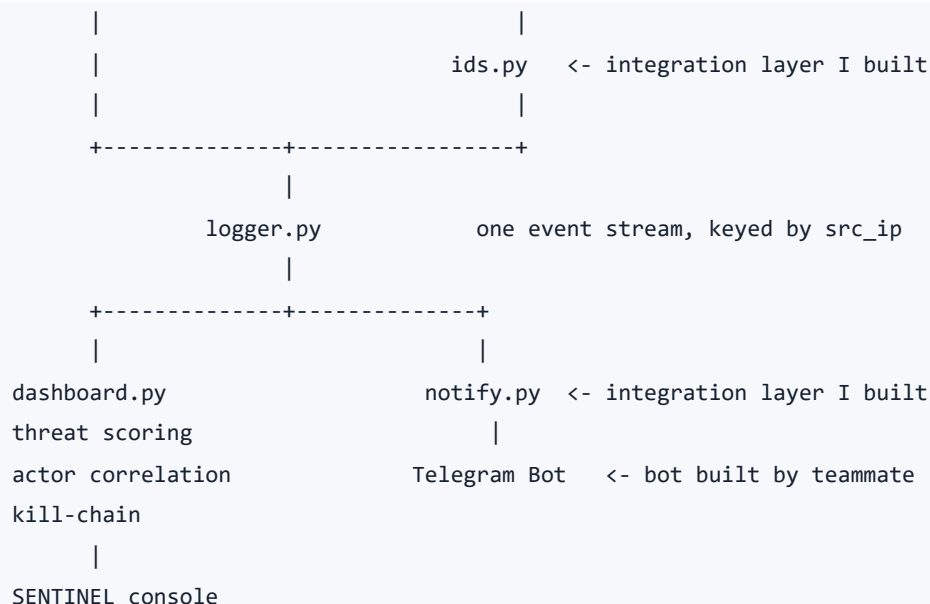
مسار في التطبيق

هذا القسم هو غرض الوثيقة الأساسي. المشروع عمل فريق، وأوضح هنا بدقة أين ينتهي عملي وأين يبدأ عمل غيري.

المكوّن	دوري	التفصيل
نظام المصيدة وتطبيق Flask	بناء كامل	المسارات، جلسات ASP.NET المحاكاة، توكنات <code>__VIEWSTATE</code> ، مسارات الطّعم، معالجات الأخطاء
قاعدة البيانات الطّعم	بناء كامل	موّلد يبنّي 575 ألف صف مفبرك عبر 15 جدولاً، وسطح حقن SQL مقصود باتصال للقراءة فقط
محرك الكشف والتصنيف	بناء كامل	31 توقيعاً عبر 6 تصنيفات هجوم، و20 نمط أداة فحص آلية
محرك بصمة الأجهزة	بناء كامل	44 إشارة، بصمات مرّجة منفصلة، وكشف تمويه بالتقاطع بين الإشارات
لوحة الرصد SENTINEL	بناء كامل	تقييم تهديد، ربط فاعلين، سلسلة هجوم، ثمانية السنة تحليلية
طبقة حماية المنظومة	بناء كامل	مصادقة، مانع إغراق، كاش تحقق، حدود طلب، تحصين ترويسات
خط السجلات وإدارته	بناء كامل	تسجيل JSONL، تدوير وأرشفة، قراءة تزايدية، كاش تجميع
بوت تليجرام	ربط فقط	البوت وسكربتته الأصلي من عمل م. عمر زيادة. دوري: بناء طبقة الربط التي توصله بتيار أحداث النظام، وسياسة التنبيه
قواعد Suricata وتدريبها	ربط فقط	ضبط المستشعر وكتابة القواعد من عمل زميل آخر. دوري: بناء وحدة الاستيعاب التي تحوّل مخرجاته وتدمجها

توضيح مهم: في الحالتين الأخيرتين لم أبّن الأداة نفسها. ما بنيته هو **طبقة التكامل** التي تجعل الأداة جزءاً من النظام: تحويل صيغة البيانات، فلترة الاتجاه، سياسة التنبيه، وإدخال المخرجات في محرك التقييم. أعتبر هذا عمل تكامل لا عمل تأليف، ولا أنسب لنفسه بناء البوت ولا تدريب قواعد الكشف.





النقطة الهندسية التي أعز بها في هذا التصميم أن `logger.py` لا يعتمد على Flask إطلاقاً — يأخذ كل شيء كوسائط صريحة. هذا ما سمح لوحدة استيعاب Suricata بالكتابة في نفس السجل من خيط خلفي دون سياق طلب، ولمحرّك التنبيهات بالاشتراك في التيار عبر خطاف دون أن يعتمد المسجل عليه.

4 المكونات التي بنيتها

4.1 الطّعم وقاعدة البيانات

البوابة تقدّم 39 صفحة مطابقة، وكل طالب يدخل يرى بياناته هو مولّدة حيّاً من القاعدة بدل لقطة ثابتة. القاعدة تُبنى برمجياً وتضم 15 ألف طالب و346 ألف علامة و575 ألف صف إجمالاً، وكلها مبركة ولا تقابل أي شخص حقيقي.

نموذج الدخول قابل للحقن **عمداً** ليكون طُعماً يسجّل تقنية المهاجم كاملة، لكن الاتصال بالقاعدة مفتوح بوضع `mode=ro`، فلا يستطيع أي حقن مهما بلغ تعديل صف واحد. هذا الفصل بين «سطح ضعيف مقصود» و«محرّك محصّن» هو جوهر تصميم المصيدة.

4.2 محرّك الكشف

يفحص كل طلب مقابل 31 توقيعاً موزّعة على ستة تصنيفات: حقن SQL، سكرت عابر، اجتياز مسارات، حقن أوامر، حقن قوالب، ورفع أصداف. ويكشف 20 أداة فحص آلية من ترويسة العميل. الهدف ليس الحجب بل التصنيف والتسجيل، لأن المصيدة تريد للمهاجم أن يكمل.

4.3 محرّك بصمة الأجهزة

سكرت يُحقن في كل صفحة ويجمع 44 إشارة من متصفح الزائر. أهمها ما يشتق من العتاد لأنه ينجو من تغيير المتصفح: بصمة الكانفاس، ومعرّفات WebGL وقدراته، ومحوّل WebGPU، وبصمة صوتية من معالجة إشارة غير مسموعة، والخطوط المثبتة.

أهم قرار في هذا المحرّك: بدل معرّف واحد مبهم، أخرجت ثلاث بصمات مركّبة منفصلة — للعتاد، وللبرمجيات، وللبيئة. النتيجة العملية أن بصمة العتاد ربطت في الاختبار **ثلاثة عناوين** بينما ربطت البصمة الكاملة اثنين فقط، لأنها نجت من

وأضفت كشف تمويه يعمل بالتقاطع بين الإشارات: تناقض بين نظام التشغيل المُعلن وبين المنصة الفعلية، ترويسة موبايل بلا دعم لمس، تعارض تلميحات العميل مع ترويسة المتصفح، ونافذة أكبر من الشاشة، ومحرك رسومات برمجي لا يظهر إلا في البيئات الوهمية.

4.4 بصمة ترتيب ترويسات HTTP

إشارة من جانب الخادم لا يستطيع الجافاسكربت تزويرها إطلاقاً. ترتيب الترويسات ومجموعتها خاصية بالمتصفح أو المكتبة التي بنت الطلب، فصارت تدقيقاً مستقلاً على بصمة العميل: من يزور كل خصائص متصفحه ويدّعي أنه Chrome يفضحه ترتيب ترويساته.

4.5 لوحة الرصد SENTINEL

مبنية على مبدأ أن اللوحة أداة تشغيل لا أداة تقارير. اللون فيها يقوده مستوى الخطورة، والأحمر محجوز للحرج وحده حتى يبقى أي بكسل أحمر إشارة تدخّل فوري. تعرض تقييم تهديد من 100 مع شرح عوامله، وربط الفاعلين، وإعادة بناء سلسلة الهجوم زمنياً لكل مصدر، وثمانية السنة: التغذية الحيّة، بيانات الدخول الملتقطة، استعلامات الحقن المنقّدة، المسارات المستهدفة، توقيعات المستشعر، التوزيع الجغرافي، ربط الفاعلين، والتشغيل.

4.6 طبقة الحماية وخط السجلات

المصيدة ضعيفة عمداً من الخارج، لكن المحرك حولها محصّن حتى لا يستطيع المهاجم القفز من الطّعم إلى المضيف أو إلى السجلات. ويشمل ذلك: مصادقة على اللوحة مع قفل تخمين، مانع إغراق لكل مصدر، حدّ لحجم الطلب، اتصال قاعدة للقراءة فقط، وحماية العمليات المدمّرة بتوكن مستقل عن كلمة المرور لمنع تزوير الطلب عبر المواقع.

هذا القسم يوضّح العمل الهندسي أكثر من قائمة الميزات.

المشكلة	التشخيص	الحل
بطء لوحة الرصد	كل طلب على اللوحة كان يشغّل اشتقاق كلمة مرور بـ 260 ألف دورة، أي 147 مّلي ثانية مقابل 2 لمسار عادي. واللوحة تستطلع كل 5 ثواني	تخزين نتيجة التحقق الناجح مؤقتاً بمفتاح مشتق من العنوان والبيانات، فنزل الطلب إلى 7 مّلي ثانية
تضخيم موارد عبر لوحة الرصد	اللوحة كانت مستثناة كلياً من مانع الإغراق، فرشّة طلبات بلا كلمة مرور تستهلك المعالج بمعامل 70 ضعفاً	إدخال اللوحة تحت مانع الإغراق، وتقييد جدول المحاولات الفاشلة الذي كان بلا سقف
تجاوز مانع الإغراق	هوية العميل كانت تؤخذ من ترويسة يتحكم بها المهاجم، فيكفي تبديلها كل طلب للإفلات	اعتماد عنوان الاتصال الفعلي، والوثوق بالترويسة فقط خلف وسيط حقيقي معلّن
ثقل السجل مع الوقت	كل استطلاع كان يحمّل السجل كاملاً ويعيد حساب كل شيء من الصفر	قراءة من ذيل الملف بكتل، وكاش تجميع بمفتاح (حجم، وقت تعديل) — والسجل إلحاقى فثبات المفتاح يعني أن الملخص لا يزال دقيقاً
ضباب التنبيهات بصمت	تنسيق الرسائل كان يكسر التحليل عند أي شرطة سفلية أو قوس زاوية، فيردّ الخادم خطأ ويضيع التنبيه دون أثر	تحويل الترميز وتهريب كل قيمة، مع إعادة إرسال احتياطية كنص خام بدل فقدان التنبيه
تضخم التقييم بضجيج المستشعر	60 تنبيهاً معلوماتياً كانت تُحسب كـ 60 هجوماً، فيظهر مصدر غير ضار بتقييم «حرج»	فصل وزن التنبيه المعلوماتي وتقييده بسقف، فنزل المصدر من 82 إلى تقييم يمكن الدفاع عنه
ظهور جهاز المستشعر كأخطر مهاجم	المستشعر يسجّل ترافيك جهازه أيضاً، وتحديثات النظام كانت تطلق تنبيهات صادرة	فلترة اتجاه: استبعاد ما مصدره المستشعر نفسه — 206 تنبيهاً من أصل 379 كانت ضجيجاً ذاتياً

6.1 ربط نظام كشف التسلل

القواعد وضبط المستشعر ليست من عملي. ما بنيته وحدة استيعاب تقرأ مخرجات المستشعر وتحوّل كل تنبيه إلى حدث بصيغة النظام، بثلاث واجهات: عرض إحصائي قبل الاستيراد، واستيراد لقطة سابقة مع الحفاظ على وقت كل تنبيه الأصلي، ومتابعة حيّة.

أهم قرار فيها كان فلترة الاتجاه. من 379 تنبيهاً في اللقطة، 206 كانت ترافيك صادراً من جهاز المستشعر نفسه. بدون هذه الفلترة يظهر جهاز الفريق كأخطر مهاجم في اللوحة. كما تحفظ الوحدة موضع القراءة، لإعادة الاستيراد لا تكرر الأحداث.

6.2 ربط بوت التنبيهات

البوت وسكربتته الأصلي من عمل م. عمر زيادة. السكربت الأصلي كان يتابع مخرجات المستشعر وحده. ما بنيته طبقة تشترك في تيار أحداث النظام كله، فصار مسار إنذار واحد يغطي هجمات التطبيق وتنبيهات الشبكة معاً، والرسالة تحمل تقييم المصدر الحالي لا مجرد خبر.

وسياسة التنبيه فيها ثلاث طبقات، لأن أرضية خطورة واحدة لا تكفي:

- خطورة الحدث المفرد، للهجمات الجادة المباشرة.
 - تقنيات تنبيه دائماً — المسح الآلي تحديداً، لأنه يُصنّف متوسطاً فتبتلعه الأرضية العالية رغم أنه أكثر ما تلتقطه أي مصيدة.
 - تصعيد يعمل عندما يرتفع تقييم المصدر التراكمي إلى فئة أعلى، حتى لو لم يكن أي طلب مفرد خطيراً. هذه الطبقة هي التي تمسك المسح البطيء.
- وأضفت تهدئة وتجميعاً، لأن تشغيل أداة حقن واحدة يولّد آلاف الأحداث، وإرسالها كما هي يوقف القناة ويجعل الجهاز غير قابل للاستخدام.

7 التحقق

لم أعتمد على أن الكود «يبدو صحيحاً»، بل تحققت من كل مسار عملياً:

- سطح الحقن مُختبر بحمولات حقيقية، والتقاط الاستعلام المنفّذ مؤكّد مع بقاء القاعدة غير قابلة للتعديل.
- حماية العمليات المدمّرة مُختبرة في أربع حالات، وكلها تُرفض بدون التوكن الصحيح.
- محاولة اجتياز مسار إلى خارج مجلد الأرشيف مرفوضة.
- سكربت البصمة مُختبر نحوياً ثم شُغّل فعلياً على متصفح مُحاكي، فأنّج حمولة بـ 44 إشارة وثلاث بصمات مرّبة.
- مسار التنبيه مُختبر بحمولة عدائية مقصودة تكسر التنسيق القديم، ووصلت سليمة بعد الإصلاح.
- الفرق بين البصمة الكاملة وبصمة العتاد مُثبت عملياً كما ورد في القسم 4.3.

البند	القيمة	ملاحظة
أسطر بايثون	4,939	موزعة على 14 وحدة
لوحة الرصد	سطر 827	واجهة مستقلة بلا أي مكتبة خارجية
صفحات البوابة	39	مطابقة، تُملاً ديناميكياً لكل طالب
صفوف قاعدة الطعم	575,250	عبر 15 جدولاً، 57 ميجابايت
توقعات الكشف	31	سنة تصنيفات هجوم
أنماط أدوات الفحص	20	كشف من ترويسة العميل
إشارات البصمة	44	ارتفعت من نحو 25
مسارات التطبيق	34	شاملة الطعم وواجهات البرمجة
تبعيات خارجية	5	لا مكتبة واجهة ولا رسوم بيانية خارجية

كامل اللوحة ومحرك البصمة والتنبيهات مكتوب بلا أي مكتبة طرف ثالث — لا إطار واجهة، ولا مكتبة رسوم، ولا عميل HTTP خارجي. هذا كان قراراً مقصوداً ليبقى النظام قابلاً للتشغيل معزولاً وقابلاً للمراجعة سطرًا بسطر.

9 ملاحظة أخلاقية

المشروع دفاعي وتعليمي. الواجهات تحاكي شكل بوابة مؤسسية لأغراض المحاكاة، لكنها غير متصلة بأي نظام حقيقي ولا تحوي أي بيانات حقيقية — كل الطلاب والعلامات والسجلات المالية مولدة برمجياً. البيانات الشخصية التي كانت في الصفحات الملتقطة أزيلت بالكامل واستُبدلت بـقالب محايد.

ويجب أن يُشغَّل في بيئة معزولة فقط. نشر نسخة تحمل شعار مؤسسة حقيقية على نطاق عام يحوّل أداة بحث دفاعي إلى صفحة تصيد، ولهذا وُضعت بوابة مصادقة تغطي كامل الواجهة عند أي نشر مستضاف.

مهدي سميح خليل مليحه — الرقم الجامعي 120235744

المستودع: github.com/mahdeps/university-honeypot